Replace and modernize legacy VPN architectures with a cloud-native Zscaler Zero Trust solution to reduce attack surface and lateral movement.

Title of the project :-

Replace and modernize legacy VPN architectures with a cloud-native Zscaler Zero Trust solution to reduce attack surface and lateral movement.

Overview :-

This project focuses on replacing traditional VPN (Virtual Private Network) architecture with a cloud-native Zero Trust security model using Zscaler. Traditional VPN systems allow users to access the entire internal network once they are authenticated, which increases security risks such as cyber-attacks and unauthorized lateral movement within the network. As organizations move toward cloud environments and remote work, legacy VPN solutions become difficult to manage, less secure, and less scalable.

The main goal of this project is to modernize the existing network security infrastructure by implementing the Zscaler Zero Trust architecture. Zero Trust follows the principle of “never trust, always verify”, meaning that every user, device, and application must be continuously authenticated and authorized before gaining access. Instead of providing full network access like a VPN, Zscaler allows users to securely connect only to specific applications they are permitted to use.

By replacing legacy VPN systems with Zscaler’s cloud-based platform, organizations can significantly reduce the attack surface and prevent lateral movement of threats inside the network. The solution also improves scalability, performance, and user experience for remote workers by providing secure access directly through the cloud. Overall, this project enhances network security, simplifies IT management, supports remote access, and protects sensitive organizational data by implementing a modern Zero Trust security framework.

In legacy VPN architecture, once a user logs in, they may get access to a large part of the internal network, which increases security risks.

The Zero Trust model verifies every user and device before allowing access and gives permission only to specific applications. By using Zscaler’s cloud platform, organizations can reduce cyber-attack risks, limit unauthorized access, and prevent lateral movement inside the network.

This modernization improves security, scalability, and remote access performance while protecting sensitive data.

ABSTRACT

Abstract: This project details the strategic migration from a legacy Virtual Private Network (VPN) infrastructure to a cloud-native Zero Trust Network Access (ZTNA) solution provided by Zscaler. The primary driver for this initiative is the fundamental inadequacy of traditional VPNs in the modern threat landscape. Legacy architectures operate on a "connect first, verify later" model, granting users broad access to the corporate network and, consequently, creating a significant risk of lateral movement by malicious actors. This expansive attack surface, combined with the operational overhead of managing physical appliances and the poor user experience associated with hair-pinned traffic, renders the existing model both insecure and inefficient for today's hybrid workforce. The proposed solution leverages the Zscaler Zero Trust Exchange, a global, cloudnative platform that shifts connectivity from a network-centric to an identity and application-centric model. By making corporate applications invisible to the internet and establishing direct, secure connections between verified users and specific applications, the new architecture eliminates the concept of network-based privileges. This approach ensures that users connect to the applications they need, not the underlying network, thereby completely neutralizing the threat of lateral movement. Furthermore, it improves performance by steering traffic directly to Zscaler's edge nodes, optimizing the user experience regardless of their location. The expected outcomes of this modernization project are multifaceted. We anticipate a drastic reduction in the organization's attack surface and the complete elimination of lateral movement risks. This will be coupled with a simplified, scalable security posture managed from a unified cloud console, reducing operational costs and complexity. Ultimately, this transition will not only fortify our cyber defenses against sophisticated threats but also enable a secure, highperformance, and agile work environment, future-proofing the organization's security architecture.

Use Case Scenarios: Scenario 1: Third-Party Vendor Access to Finance Application An external auditor needs temporary access to the university's finance application for end-ofyear reconciliation. Instead of provisioning a VPN account, ZPA grants time-bound, applicationspecific access. The vendor authenticates via identity provider and is micro-segmented away from all other internal resources.

Output:

• User identity verified (External_Auditor_Group)

• Time-bound access policy enforced (7-day validity)

• Connection restricted to Finance Application only

• No lateral movement possible to other systems

Scenario 2: Research Assistant Access to High-Performance Computing Cluster A graduate student requires SSH access to an on-premises research computing cluster to run data analysis scripts. Using ZPA, they connect directly to the cluster without exposing SSH ports to the internet or requiring a full network-level VPN tunnel.

Output:

• User identity verified (Research_Assistant_Group)

• Protocol-specific access granted (SSH only)

• Direct micro-tunnel established to HPC Cluster

• All other network segments remain inaccessible

Scenario 3: Administrative Staff Access to Internal File Server An administrative assistant working from a campus satellite office needs to access a sensitive file server containing student records. ZPA verifies their device compliance and routes them exclusively to the file server application, with all traffic inspected inline for data loss prevention.

Output:

• User identity verified (Admin_Staff_Group)

• Device posture compliant (Disk encryption enabled, patch level current)

• Granular file access policies enforced (Read/Write permissions)

• Data Loss Prevention (DLP) policies active

Scenario 4: IT Administrator Secure Access to Server Management Interfaces A systems administrator requires RDP access to manage critical Windows servers in the data center. Using ZPA, they connect directly to the target servers without exposing RDP to the internet, while all administrative sessions are recorded for audit compliance.

Output:

- User identity verified (IT_Admin_Group)
- Privileged access workflow triggered (Approval required)
- Session recording and monitoring active
- Micro-tunnel established to specific server IP and port only

Scenario 5: Visiting Professor Access to Library Resources A visiting professor from a partner institution needs temporary access to digitized archives stored on an internal library application server. ZPA provides just-in-time access without placing the visiting scholar on the internal network, ensuring separation from administrative systems.

Output:

- User identity verified (Visiting_Faculty_Group)
- Just-in-time access provisioned (8-hour session limit)
- Connection restricted to Library Application Server
- Full network segmentation maintained

List of teammates–

S.no	Student name	college	contact
1.	K.NIVETHA	SASURIE COLLEGE OF ARTS AND SCIENCE,Vijayamangalam	nivethakrishna2005@gmail.com
2.	S.PUJA RANI OJHA	SASURIE COLLEGE OF ARTS AND SCIENCE,Vijamangalam	Poojasukanth89@gmail.com
3.	K.PIRUTHIKA	SASURIE COLLEGE OF ARTS AND SCIENCE,Vijayamangalam	Prithikaprithika157@gmail.com
4.	B.LOGEETHA	SASURIE COLLEGE OF ARTS AND SCIENCE,Vijayamangalam	Logimalogima2@gmail.com
5.	A.PADMA SRI	SASURIE COLLEGE OF ARTS AND SCIENCE,Vijayamangalam	Padmasriarul53@gmail.com

List of Vulnerability Table:

S.no	Vulnerability Name	CWE/CVE - No
1.	Broken Access Control	CWE-22
2.	Security Misconfiguration	CWE-11
3.	Software Supply Chain Failures	CWE-447
4.	Cryptographic Failures	CWE-261
5.	Injection	CWE-20
6.	Insecure Design	CWE-73
7.	Authentication Failures	CWE-258
8.	Software or Data Integrity Failures	CWE-426
9.	Security Logging & Alerting Failures	CWE-221
10.	Mishandling of Exceptional Conditions	CWE-234

REPORT:-

1.Vulnerability Name:- Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal')

CWE/CVE : - CWE-22

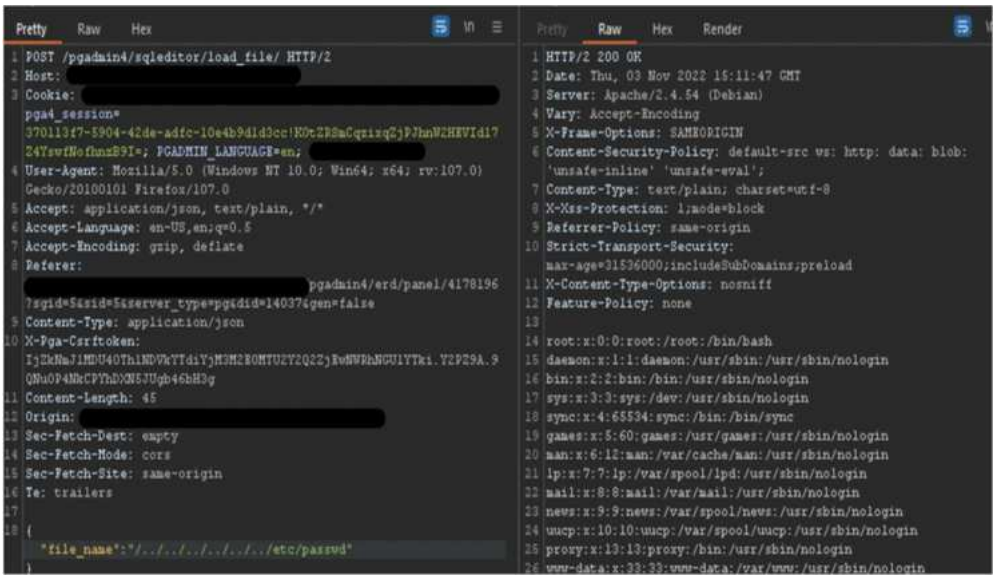
OWASP/SANS Category:- A01:2025 Broken Access Control

Description:-

Improper Limitation of a Pathname to a Restricted Directory is a security vulnerability where a program does not properly control file paths given by the user. Because of this, attackers may access files outside the allowed directory using path traversal methods like ../. This can expose sensitive files and data. Proper input validation and access control are required to prevent this issue.

Business Impact::-

- Unauthorized access to sensitive company data.
- Leakage of confidential information.
- Damage to company reputation and customer trust.
- Financial loss due to data breaches.
- Legal and compliance issues.



Recommendation:

- **Validate user input:** Ensure all user inputs related to file paths are properly validated and restricted.
- **Use whitelist validation:** Allow only specific, approved file names or directories instead of accepting all inputs.
- **Avoid direct user input in file paths:** Do not directly use user-provided data to construct file paths.
- **Use secure APIs and libraries:** Utilize built-in functions that safely handle file operations.
- **Restrict directory access:** Configure the application so it can access only necessary directories.
- **Normalize file paths:** Remove or block special characters such as ../ that are commonly used in path traversal attacks.
- **Implement proper access controls:** Ensure that users can only access files they are authorized to view.
- **Regular security testing:** Perform vulnerability scanning and code reviews to detect path traversal issues.

2.Vulnerability Name:- ASP.NET Misconfiguration: Creating Debug Binary

CWE/CVE : - CWE-11

OWASP/SANS Category:- A02:2025 Security Misconfiguration

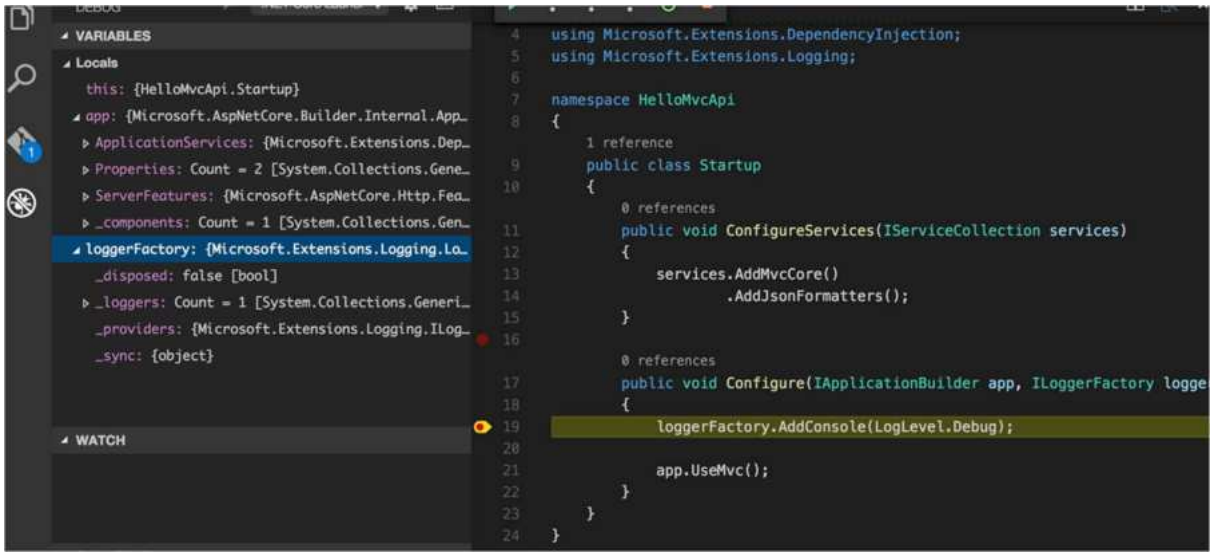
Description:-

Creating Debug Binary occurs when an ASP.NET application is deployed with the **debug mode enabled** in the configuration file. In ASP.NET, developers use debug mode during development to identify errors and test the application easily. However, if the application is published with debug settings turned on, it generates **debug binaries** instead of optimized release binaries. These debug binaries may contain additional debugging information such as detailed error messages, stack traces, and internal code details.

Business Impact::-

- Exposes **detailed error messages and stack traces** that reveal internal application information.

- Helps attackers **understand the application structure** and find vulnerabilities.
- Increases risk of **unauthorized access or cyber attacks**.
- Causes **reduced application performance** because debug binaries are not optimized.
- Leads to **slow response time and poor user experience**.
- May result in **data breaches or system compromise**.
- Can cause **financial loss and reputational damage** to the organization.
- Reduces **customer trust and business reliability**.



Recommendations :

- **Disable debug mode in production:** Ensure the debug attribute in the web.config file is set to **false** before deploying the application.
- **Use release build configuration:** Always compile and deploy the application using **Release mode** instead of Debug mode.
- **Remove debugging information:** Avoid including detailed debugging information in production binaries.
- **Implement proper configuration management:** Maintain separate configuration settings for development and production environments.
- **Restrict error message details:** Configure the application to display **generic error messages** to users instead of detailed system information.
- **Perform security reviews before deployment:** Check application configuration settings during testing and deployment stages.

- **Regularly update and maintain the application:** Ensure the system follows secure development and deployment practices.

3.Vulnerability Name:- Unimplemented or Unsupported Feature in UI

CWE/CVE : CWE-447

OWASP/SANS Category:-A03:2025 Software Supply Chain Failures

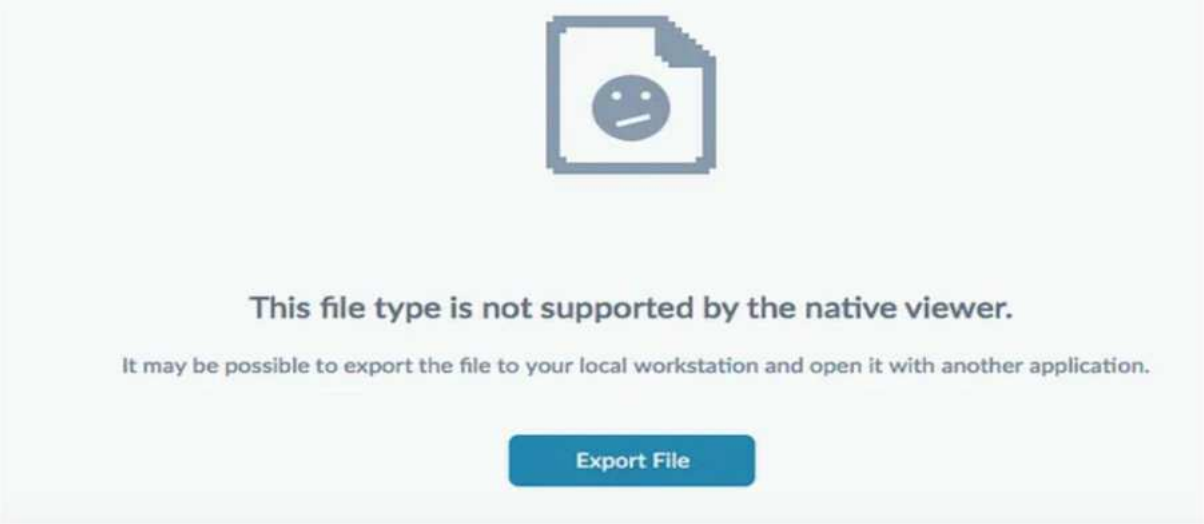
Description:-

An **Unimplemented or Unsupported Feature in the User Interface (UI)** occurs when a feature or option is visible in the application interface but is not actually implemented or supported by the system. This means the UI element (such as a button, link, or menu option) is present, but it does not perform the expected function when used.

This issue usually happens due to incomplete development, improper configuration, or leftover UI components from earlier versions of the application. When users interact with these features, they may experience errors, broken links, or no response from the system.

Business Impact::-

- Creates **confusion for users** when features do not work as expected.
- Leads to a **poor user experience** and reduces usability of the application.
- Decreases **customer satisfaction and trust** in the product.
- May expose **system errors or internal information** if error messages appear.
- Increases **support requests and maintenance efforts**.
- Can affect the **reputation and reliability of the organization**.
- May lead to **loss of users or business opportunities**.



Recommendations :

- **Remove unused UI elements:** Delete buttons, links, or menu options that are not implemented.
- **Disable incomplete features:** Temporarily disable features that are still under development.
- **Provide proper error handling:** Display clear and user-friendly messages if a feature is unavailable.
- **Conduct thorough testing:** Test the application before release to ensure all visible features work correctly.

4.Vulnerability Name:- Weak Encoding for Password

CWE/CVE : CWE-261

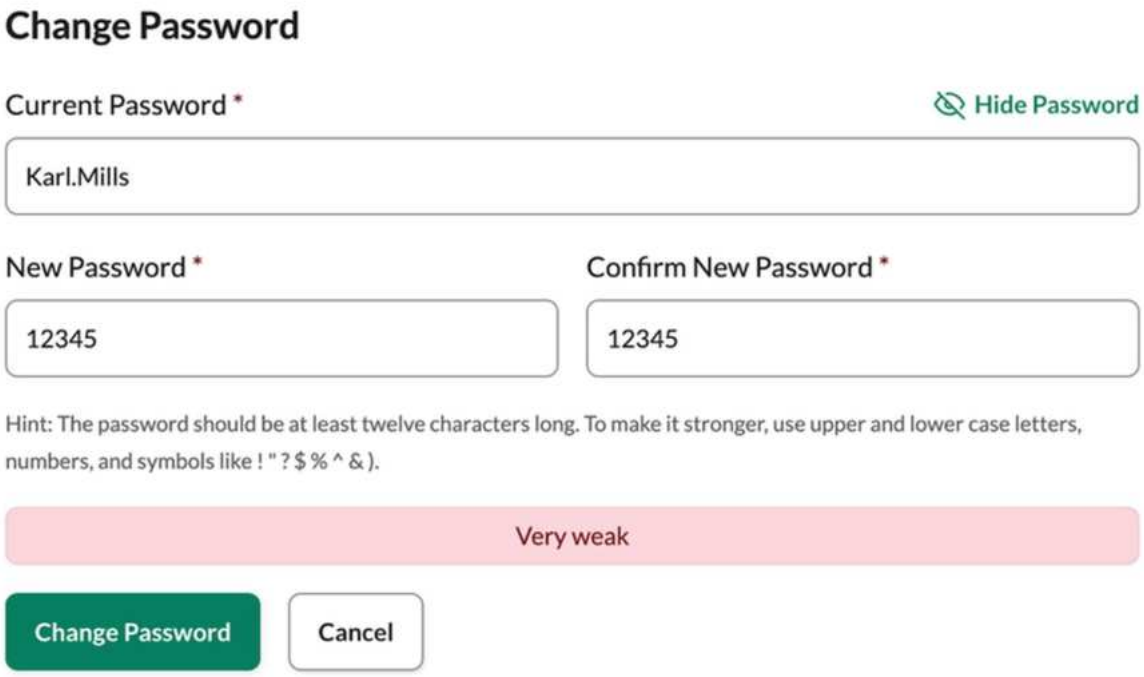
OWASP/SANS Category:- A04:2025 Cryptographic Failures

Description:-

Weak Encoding for Password refers to the use of insecure or easily reversible methods to store or transmit user passwords in an application. Instead of using strong hashing algorithms with proper security techniques, some systems use simple encoding or weak encryption methods to protect passwords. These methods can be easily decoded or cracked by attackers using common tools.If passwords are stored using weak encoding, attackers who gain access to the database or system files can quickly retrieve the original passwords. This can lead to unauthorized access to user accounts and sensitive information. Therefore, applications should use strong password protection techniques such as secure hashing algorithms and proper security practices to ensure that passwords remain protected.

Business Impact::-

- Increases the risk of unauthorized access to user accounts.
- Attackers may easily decode or crack stored passwords.
- Can lead to data breaches and exposure of sensitive information.
- Causes loss of customer trust in the organization.
- May result in financial loss and legal issues.
- Damages the company’s reputation and brand image.
- Increases security risks across the system if users reuse passwords.



Recommendations :

- **Use strong hashing algorithms:** Store passwords using secure hashing methods such as bcrypt, PBKDF2, or Argon2.
- **Apply salting techniques:** Add a unique random value (salt) to each password before hashing to prevent cracking.
- **Avoid reversible encoding methods:** Do not store passwords using simple encoding or weak encryption.
- **Implement strong password policies:** Require users to create complex and secure passwords.

5.Vulnerability Name:- Improper Input Validation

CWE/CVE : CWE-20

OWASP/SANS Category:- A05:2025 Injection

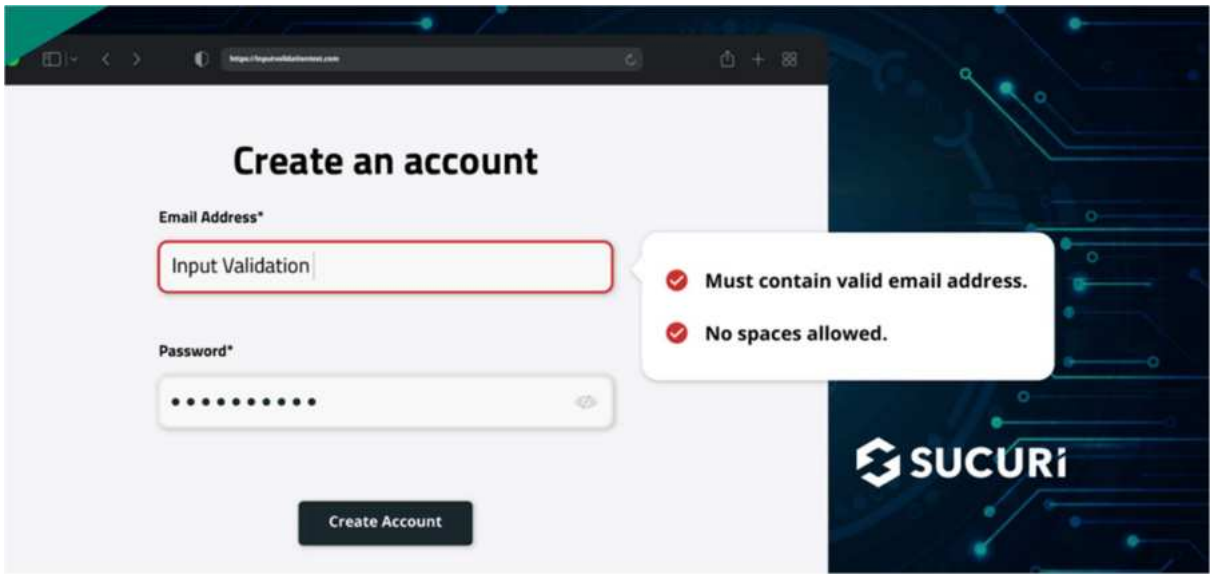
Description:-

Improper Input Validation occurs when an application does not properly check or verify the data entered by users before processing it. Applications usually accept input through forms, URLs, or APIs. If this input is not validated correctly, attackers may provide unexpected

or malicious data to manipulate the system's behavior.This vulnerability can allow attackers to perform different types of attacks such as injecting malicious code, bypassing security controls, or accessing unauthorized data. Improper input validation can occur when the application fails to check the format, length, type, or range of the input data.To prevent this issue, applications should implement strong input validation techniques to ensure that only valid and expected data is accepted by the system.

Business Impact::-

- May lead to unauthorized access to sensitive information.
- Increases the risk of data breaches and system compromise.
- Can cause application malfunction or system crashes.
- Results in financial loss and operational disruption.
- Damages the organization's reputation and customer trust.
- Increases security risks and maintenance costs for the company.



Recommendations

- **Validate all user inputs:** Check the format, length, type, and range of all input data.
- **Use whitelist validation:** Accept only expected and allowed input values.
- **Sanitize user input:** Remove or escape special characters that could be used for attacks.
- **Implement server-side validation:** Always validate inputs on the server side in addition to client-side checks.
- **Use secure coding practices:** Follow secure development standards to prevent injection attacks.

- **Perform regular security testing:** Conduct vulnerability scans and code reviews to identify input validation issues.

6.Vulnerability Name:- External Control of File Name or Path

CWE/CVE : CWE-73

OWASP/SANS Category:- A06:2025 Insecure Design

Description:-

External Control of File Name or Path occurs when an application allows users to specify or control the file name or file path used by the system without proper validation or restrictions. This means the application directly uses user-supplied input to access, create, read, or modify files on the server.If this input is not properly validated, attackers can manipulate the file path to access unauthorized files or directories. For example, they may attempt to perform directory traversal attacks to view sensitive system files or modify important application data.This vulnerability can expose confidential information and compromise the security of the system. Therefore, applications should strictly validate user input and restrict file access only to authorized directories and files.

Business Impact::-

- Attackers may gain unauthorized access to sensitive files.
- Can lead to exposure of confidential data such as system or user information.
- May allow attackers to modify or delete important files.
- Increases the risk of system compromise or further cyber attacks.
- Causes data loss or service disruption.
- Results in financial loss and operational issues for the organization.

7.Vulnerability Name:- Empty Password in Configuration File

CWE/CVE : CWE-258

OWASP/SANS Category:- A07:2025 Authentication Failures

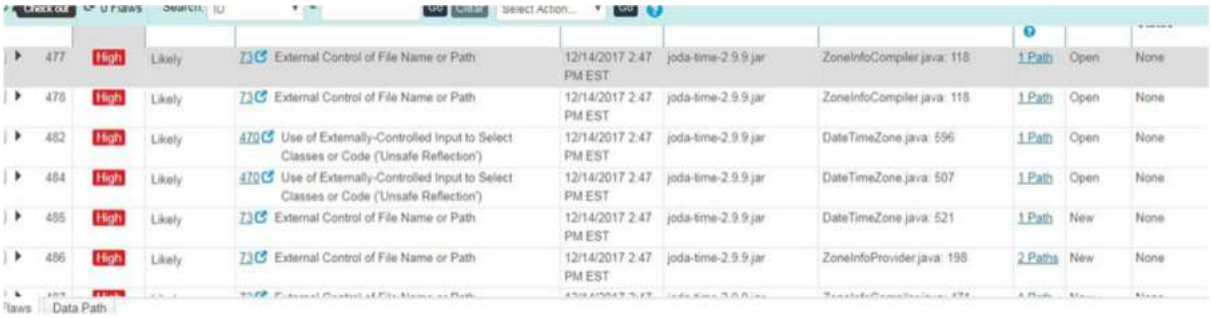
Description:-

Empty Password in Configuration File refers to a security issue where a configuration file contains a username or account setting with a blank or missing password. Configuration files are commonly used to store important system settings

such as database credentials, API keys, or service account details. If the password field is left empty, it means that the system may allow access without proper authentication.This misconfiguration can occur due to poor security practices, testing configurations being moved to production, or developers forgetting to set a secure password. Attackers who discover such configurations may gain unauthorized access to the system, database, or other sensitive resources.To prevent this issue, all configuration files should use strong and secure passwords, and sensitive credentials should be properly protected.

Business Impact::-

- Allows unauthorized access to systems or databases.
- Increases the risk of data breaches and exposure of sensitive information.
- Attackers may modify, delete, or steal important data.
- Can lead to system compromise and security attacks.
- Causes financial loss and operational disruption.
- Damages the organization's reputation and customer trust.
- May result in compliance and legal issues for the company.



477	High	Likely	73	External Control of File Name or Path	12/14/2017 2:47 PM EST	joda-time-2.9.9.jar	ZoneInfoCompiler.java: 118	1 Path	Open	None
478	High	Likely	73	External Control of File Name or Path	12/14/2017 2:47 PM EST	joda-time-2.9.9.jar	ZoneInfoCompiler.java: 118	1 Path	Open	None
482	High	Likely	470	Use of Externally-Controlled Input to Select Classes or Code ('Unsafe Reflection')	12/14/2017 2:47 PM EST	joda-time-2.9.9.jar	DateTimeZone.java: 596	1 Path	Open	None
484	High	Likely	470	Use of Externally-Controlled Input to Select Classes or Code ('Unsafe Reflection')	12/14/2017 2:47 PM EST	joda-time-2.9.9.jar	DateTimeZone.java: 507	1 Path	Open	None
485	High	Likely	73	External Control of File Name or Path	12/14/2017 2:47 PM EST	joda-time-2.9.9.jar	DateTimeZone.java: 521	1 Path	New	None
486	High	Likely	73	External Control of File Name or Path	12/14/2017 2:47 PM EST	joda-time-2.9.9.jar	ZoneInfoProvider.java: 198	2 Paths	New	None

Recommendations :

- **Set strong passwords:** Ensure all configuration files use strong and unique passwords.
- **Avoid empty or default credentials:** Never leave password fields blank in configuration settings.
- **Secure configuration files:** Restrict access permissions so only authorized users can view or modify them.
- **Use secure credential management:** Store sensitive information using secure methods such as environment variables or encrypted storage.

8.Vulnerability Name:- Untrusted Search Path

CWE/CVE : CWE-426

OWASP/SANS Category:- A08:2025 Software or Data Integrity Failures

Description:-

Untrusted Search Path is a security vulnerability that occurs when an application searches for and loads files or executable programs from directories that are not trusted or properly controlled. When the system looks for a required file, it follows a predefined search path. If this path includes directories that attackers can modify, they may place malicious files in those locations.When the application runs, it may unknowingly load and execute the malicious file instead of the legitimate one. This can allow attackers to run unauthorized code on the system and gain control over the application.To prevent this issue, applications should use secure and trusted directories, specify the full path for files, and restrict access permissions to prevent unauthorized modifications.

Business Impact::-

- Can lead to **unauthorized access and system compromise**.
- Increases the risk of **malware installation or further cyber attacks**.
- May result in **data theft or modification of important files**.
- Causes **system instability or service disruption**.
- Leads to **financial loss and operational issues**.
- Damages the **organization's reputation and customer trust**.

snowflakedb/snowflake-jdbc

Untrusted search path on Windows

Package

snowflake-jdbc (Maven)

Recommendations :

- **Use absolute paths:** Always specify the full path when loading executables or libraries.
- **Avoid relative paths:** Do not rely on system search paths to locate files.

- **Restrict directory permissions:** Ensure untrusted users cannot write to directories in the search path.
- **Conduct regular security checks:** Perform vulnerability scanning and code reviews to detect such issues.

9.Vulnerability Name:- Information Loss or Omission

CWE/CVE : CWE-221

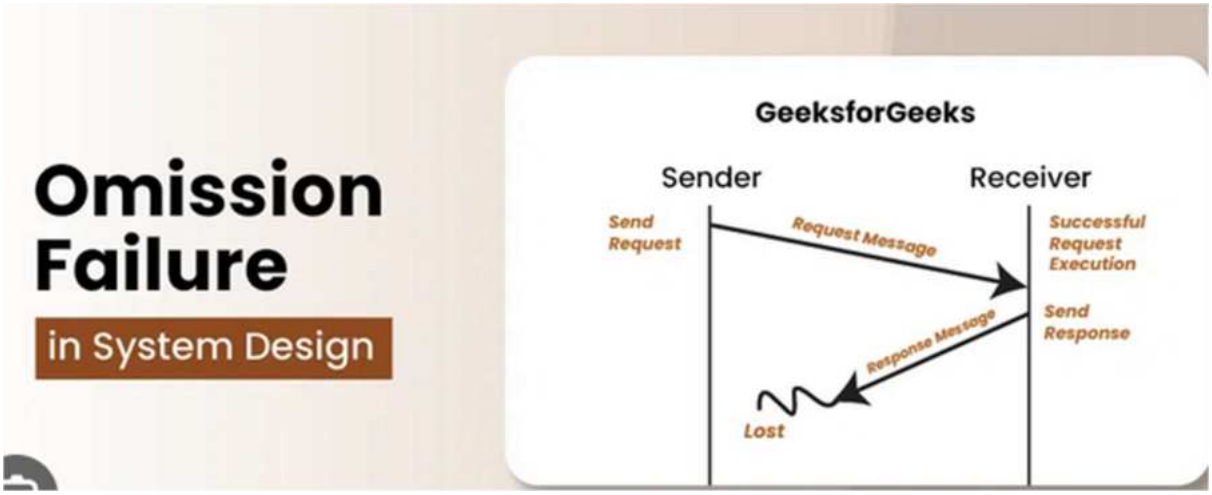
OWASP/SANS Category:- A09:2025 Security Logging & Alerting Failures

Description:-

Information Loss or Omission occurs when important or required information is missing, removed, or not properly included in an application, system output, or documentation. This can happen due to improper data handling, system errors, incomplete implementation, or poor configuration.When essential information is omitted, users or systems may not receive the complete data needed to perform tasks correctly. This can lead to incorrect processing, misunderstanding of system responses, or incomplete records.Such issues can affect the reliability and accuracy of the application and may cause operational problems. Therefore, systems should ensure that all necessary information is properly captured, stored, and displayed to maintain data integrity and reliability.

Business Impact::-

- Leads to incomplete or inaccurate data processing.
- May cause errors in decision-making due to missing information.
- Affects the reliability and integrity of the system.
- Can result in operational delays or workflow issues.
- Increases maintenance and troubleshooting efforts.
- May cause financial loss or business inefficiency.
- Damages the organization’s credibility and user trust.



Recommendations :

- **Ensure complete data handling:** Verify that all required information is properly captured, stored, and transmitted.
- **Implement proper validation checks:** Validate data before processing to avoid missing or incomplete information.
- **Maintain proper logging and error handling:** Record system activities to detect and prevent data loss.
- **Perform regular testing and reviews:** Test the system frequently to ensure no important information is omitted.

10.Vulnerability Name:- Failure to Handle Missing Parameter

CWE/CVE : CWE-234

OWASP/SANS Category:- A10:2025 Mishandling of Exceptional Conditions

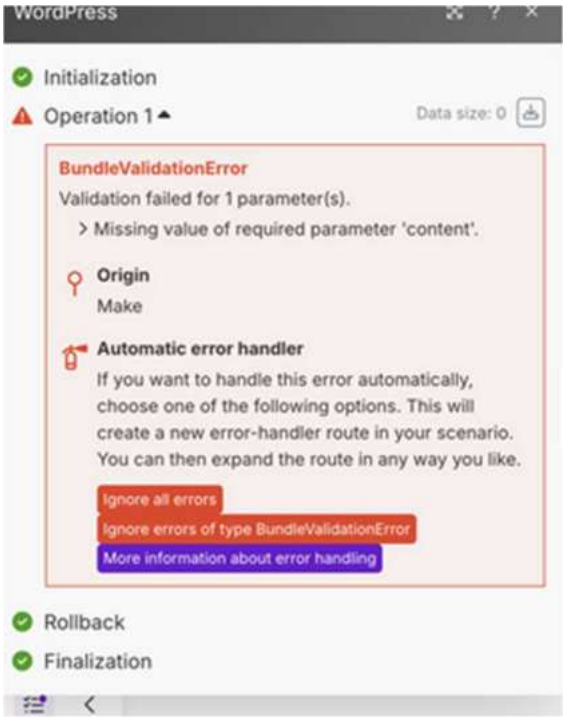
Description:-

Failure to Handle Missing Parameter occurs when an application does not properly check or manage situations where required input parameters are missing from a request. Many applications depend on parameters such as user inputs, query strings, or form data to perform specific operations. If the application assumes that these parameters will always be present and does not validate them, the system may behave unexpectedly when they are missing.This can lead to application errors, crashes, or incorrect processing of requests. In some cases, it may also expose system information through error messages or allow attackers to manipulate the application's behavior.To prevent this issue,

applications should implement proper validation and error handling to ensure that all required parameters are present before processing the request.

Business Impact::-

- Causes application errors or system crashes.
- Leads to unexpected behavior in the application.
- May expose internal system information through error messages.
- Affects the reliability and stability of the application.
- Creates poor user experience and user frustration.
- Increases maintenance and troubleshooting efforts.
- Can damage the organization's reputation and customer trust.



Recommendations:

- **Implement proper error handling:** Display clear error messages when parameters are missing.
- **Set default values:** Provide safe default values for optional parameters when possible.
- **Perform input validation and testing:** Regularly test the application to ensure it handles missing parameters correctly.

Overview of Nessus Vulnerability Scanner

Nessus is one of the most widely used vulnerability scanning tools in the field of cybersecurity. It is developed by Tenable and is designed to help organizations identify security weaknesses in their systems, networks, and applications. Nessus scans computers, servers, networks, and web applications to detect vulnerabilities that could be exploited by attackers. By identifying these security flaws early, organizations can take appropriate measures to protect their systems and sensitive information.

Nessus works by performing automated vulnerability assessments. It scans systems using a large database of known vulnerabilities, misconfigurations, outdated software versions, and security risks. The tool compares the system configuration and installed software against its vulnerability database and reports any potential issues. These vulnerabilities may include weak passwords, missing security patches, configuration errors, open ports, and insecure services. After completing the scan, Nessus generates a detailed report that describes the vulnerabilities, their severity level, and recommended solutions to fix them.One of the important features of Nessus is its ability to categorize vulnerabilities based on severity levels such as low, medium, high, and critical. This helps security teams prioritize the most serious security issues first. The tool also provides detailed explanations of each vulnerability, including technical descriptions, possible risks, and remediation steps. This makes it easier for administrators and security professionals to understand the problem and apply the correct fixes.Nessus supports different types of scans such as network scanning, host scanning, compliance scanning, and web application scanning. Network scanning helps identify vulnerabilities in network devices like routers, switches, and servers. Host scanning analyzes individual systems for missing patches, outdated software, and configuration issues. Compliance scanning checks whether systems follow security standards and policies. Web application scanning helps identify vulnerabilities such as injection attacks and security misconfigurations in web-based applications.Another advantage of Nessus is its large and frequently updated vulnerability database. The developers regularly update the tool with new vulnerability checks to ensure that the scanner can detect the latest security threats. This helps organizations stay protected against newly discovered vulnerabilities and cyber attacks. Nessus also provides a user-friendly interface that allows users to easily configure scans, monitor results, and generate reports.Nessus plays a significant role in vulnerability management. Instead of waiting for attackers to exploit weaknesses, organizations can proactively identify and fix vulnerabilities using Nessus. It helps improve the overall security posture of an organization by reducing the chances of cyber attacks, data breaches, and system compromises. Security teams often integrate Nessus into their regular security assessment processes to continuously monitor and maintain system security.In conclusion, Nessus is a powerful vulnerability scanning tool that helps organizations detect and manage security risks in their IT infrastructure.

Target website : **http://testfire.net/**

Target ip address:65.61.137.117

List of vulnerability:

S.no	Vulnerability name	Severity	plugins
1.	TLS Version 1.0 Protocol Detection	MEDIUM	104743
2.	TLS Version 1.1 Protocol Deprecated	MEDIUM	157288
3.	Additional DNS Hostnames	INFO	10114
4.	Apache Tomcat Detection	INFO	39446
5.	Common Platform Enumeration(CPE)	INFO	45590
6.	Device Type	INFO	54615
7.	HSTS Missing From HTTPS Server	INFO	84502
8.	HTTP Server Type and Version	INFO	10107

REPORT:-

Vulnerability Name:- 104743 - TLS Version 1.0 Protocol Detection

severity : - MEDIUM

Plugin:- 104743

Port :- 443

Description:-

Transport Layer Security 1.0 Protocol Detection refers to a security finding that occurs when a system or server is found to support the outdated TLS 1.0 encryption protocol. TLS is used to secure communication between clients and servers over a network, especially for web applications and online services. However, TLS 1.0 is considered outdated and insecure because it contains known cryptographic weaknesses.If a server still allows TLS 1.0 connections, attackers may exploit these weaknesses to perform attacks such as data interception or man-in-the-middle attacks. This could expose sensitive information such as login credentials, personal data, or financial details.Modern security standards recommend disabling TLS 1.0 and using stronger protocols such as Transport Layer Security 1.2 or Transport Layer Security 1.3, which provide improved encryption and stronger security for network communications.

solution:- Configure the server to disable Transport Layer Security 1.0 support. Use stronger and secure versions such as Transport Layer Security 1.2 or Transport Layer Security 1.3.

Business Impact::-

- Increases the risk of **data interception during communication**.
- Attackers may perform **man-in-the-middle attacks** and steal sensitive information.
- Can expose **user credentials, personal data, or financial details**.
- May lead to **non-compliance with modern security standards and regulations**.
- Causes **loss of customer trust and damage to the organization's reputation**.
- Can result in **financial loss and potential legal issues** for the organization.

Vulnerability Name:- TLS Version 1.1 Protocol Deprecated

severity : - MEDIUM

Plugin:- 157288

Port :-443

Description:-

Transport Layer Security 1.1 Protocol Deprecated refers to a security finding that occurs when a server or application still supports the TLS 1.1 protocol for secure communication. TLS is used to encrypt data transmitted between clients and servers, such as web browsers and web applications. However, TLS 1.1 is considered outdated and has been deprecated due to known security weaknesses and the availability of stronger encryption standards.Security organizations and modern browsers have stopped supporting TLS 1.1 because it does not provide sufficient protection against modern cyber threats. If a system allows TLS 1.1 connections, attackers may exploit these weaknesses to intercept or manipulate sensitive data during transmission.To maintain strong security, organizations should disable TLS 1.1 and use more secure versions such as Transport Layer Security 1.2 or Transport Layer Security 1.3, which provide stronger encryption and improved protection for network communications.

solution:- Configure servers to disable Transport Layer Security 1.1 support. Use stronger protocols such as Transport Layer Security 1.2 or Transport Layer Security 1.3.

Business Impact::-

- Increases the risk of **data interception and security attacks**.
- Sensitive information such as **user credentials and personal data** may be exposed.
- May lead to **non-compliance with modern security standards and regulations**.
- Can result in **data breaches and system compromise**.
- Causes **loss of customer trust and reputation damage** for the organization.
- May lead to **financial loss and legal consequences**.

Vulnerability Name:- Additional DNS Hostnames

severity : - INFO

Plugin:- 10114

Port :-443

Description:-

Domain Name System Additional DNS Hostnames refers to a situation where multiple hostnames or domain names are associated with a single server or IP address. During a vulnerability scan, the system may detect extra DNS hostnames that point to the same target

server. These additional hostnames may include subdomains, alternative domain names, or previously configured host entries.Sometimes these hostnames are intentionally configured for services such as load balancing, multiple websites on the same server, or internal system access. However, in some cases, unused or unknown hostnames may expose additional entry points to the server. Attackers could use this information to discover hidden services, misconfigurations, or unprotected applications running on the same system.Therefore, organizations should regularly review and manage DNS records to ensure that only required and authorized hostnames are active and properly secured

solution:- Regularly check all Domain Name System records and identify unnecessary or unknown hostnames. Delete or disable DNS entries that are no longer required**.**

Business Impact::-

- May expose **additional entry points** to the server for attackers.
- Attackers may discover **hidden services or applications**.
- Increases the risk of **security misconfigurations and unauthorized access**.
- Can lead to **data breaches or system compromise**.
- Causes **security management difficulties** due to multiple unmanaged hostnames.
- May damage the **organization's reputation and customer trust** if exploited.

Vulnerability Name:- Apache Tomcat Detection

severity : - INFO

Plugin:- 39446

Port :-443

Description:-

Apache Tomcat Detection refers to the identification of an Apache Tomcat server running on a system during a vulnerability scan. Apache Tomcat is a widely used open-source web server and servlet container developed by the Apache Software Foundation that is used to deploy and run Java-based web applications.When a vulnerability scanning tool detects Apache Tomcat, it means that the server is accessible on the network and responding to requests. The detection itself is not necessarily a vulnerability, but it indicates that the service is active and may need to be reviewed for potential security risks. If the

Tomcat server is outdated, misconfigured, or exposed to the internet without proper security controls, attackers could attempt to exploit known vulnerabilities.Therefore, organizations should ensure that Apache Tomcat servers are properly configured, regularly updated, and protected with strong authentication and security settings to prevent unauthorized access

solution:- Regularly update Apache Tomcat to the latest stable version to fix known vulnerabilities.Limit access to the Tomcat management interface using strong authentication and IP restrictions.

Business Impact::-

- May expose the **web application server** to potential cyber attacks.
- If outdated, attackers may exploit **known vulnerabilities** in Apache Tomcat.
- Can lead to **unauthorized access to applications or sensitive data**.
- May result in **system compromise or service disruption**.
- Causes **financial loss and operational issues** for the organization.
- Can damage the **organization's reputation and customer trust**.

Vulnerability Name:- Common Platform Enumeration(CPE)

severity : - INFO

Plugin:- 45590

Port :- 443

Description:-

Common Platform Enumeration is a standardized method used to identify and name software applications, operating systems, and hardware platforms. It provides a consistent naming format that helps security tools and organizations accurately recognize specific technologies used in a system.CPE is commonly used in vulnerability management and security scanning tools to match identified software or platforms with known vulnerabilities listed in security databases. By using standardized CPE names, security systems can easily determine whether a particular product version is affected by known security issues.This standard helps improve vulnerability detection, security analysis, and

system management by providing a uniform way to describe different technology platforms across various security tools and databases.

solution:-Regularly update software, operating systems, and hardware platforms identified through Common Platform Enumeration to the latest secure versions.Install vendor-released patches to fix vulnerabilities associated with identified platforms.

Business Impact::-

- Attackers may identify specific software or platform versions running on the system.
- Can help attackers find known vulnerabilities related to those platforms.
- Increases the risk of targeted cyber attacks.
- May lead to unauthorized access or system compromise.
- Can cause data breaches and service disruptions.
- Results in financial loss and reputational damage to the organization.

Vulnerability Name:- Device Type

severity : - INFO

Plugin:- 54615

Port :-443

Description:-

Device Type refers to the identification of the category or type of device detected during a network or vulnerability scan. Security scanning tools analyze system responses, network behavior, and configuration details to determine whether the detected device is a server, workstation, router, firewall, printer, mobile device, or another type of network equipment.Identifying the device type helps security teams understand the role of each system within the network infrastructure. This information allows administrators to apply appropriate security policies, monitor device behavior, and identify potential vulnerabilities related to specific device types.Although device type detection itself is not a vulnerability, it provides useful information about the system environment that can assist in security management and vulnerability assessment.

solution:- Configure systems to avoid revealing unnecessary device details during network scans.Restrict unauthorized devices from connecting to the network.Ensure all devices are regularly updated with the latest security patches.

Business Impact::-

- Attackers may identify **types of devices** used in the network.
- Helps attackers plan **targeted attacks** on specific devices.
- May expose **network infrastructure details**.
- Increases the risk of **unauthorized access or exploitation**.
- Can lead to **network security weaknesses** if devices are not properly secured.
- May result in **operational disruption and reputational damage**.

Vulnerability Name:- HSTS Missing From HTTPS Server

severity : - INFO

Plugin:- 84502

Port :- 443

Description:-

HTTP Strict Transport Security Missing From HTTPS Server is a security finding that occurs when a web server supports HTTPS but does not implement the HSTS security policy. HSTS is a web security mechanism that forces web browsers to communicate with the server only through secure HTTPS connections instead of HTTP.When HSTS is not enabled, users may still access the website through an unsecured HTTP connection. Attackers can exploit this situation to perform man-in-the-middle attacks, where they intercept or manipulate the communication between the user and the server. This may expose sensitive data such as login credentials, personal information, or session cookies.Enabling HSTS ensures that browsers automatically connect to the website using HTTPS, which helps protect user data and improves the overall security of web communications.

solution:- Configure the server to implement HTTP Strict Transport Security by adding the Strict-Transport-Security header.Redirect all HTTP traffic to HTTPS to ensure secure communication.Configure max-age, includeSubDomains, and preload settings for better protection.

Business Impact::-

- Increases the risk of **man-in-the-middle attacks**.
- Sensitive information such as **login credentials and user data** may be exposed.
- Can lead to **data breaches and unauthorized access**.
- Causes **loss of customer trust and reputational damage**.
- May result in **financial loss and compliance issues** for the organization.

Vulnerability Name:- HTTP Server Type and Version

severity : - INFO

Plugin:- 10107

Port :- 443

Description:-

Hypertext Transfer Protocol Server Type and Version disclosure occurs when a web server reveals detailed information about the server software and its version in the HTTP response headers. This information may include the name of the web server and its version number, such as Apache HTTP Server or Microsoft Internet Information Services.During a vulnerability scan, the server may respond with headers that expose these details. Although this is not always a direct vulnerability, it provides useful information for attackers. By knowing the exact server type and version, attackers can search for known vulnerabilities related to that specific software version and attempt targeted attacks.To reduce security risks, organizations should minimize the amount of information disclosed by the web server and keep server software updated.

solution:- Configure the web server to remove or mask the server type and version from HTTP response headers. Regularly update the web server to the latest secure version.Remove headers that expose system or software details**.**

Business Impact::-

- Attackers may identify **specific server software and versions** used by the organization.
- Increases the risk of **targeted attacks based on known vulnerabilities**.
- May lead to **unauthorized access or system exploitation**.
- Can cause **data breaches or service disruptions**.
- Results in **financial loss and reputational damage** for the organization.

REPORT

Tittle :- Replace and modernize legacy VPN architectures with a cloud-native Zscaler Zero Trust solution to reduce attack surface and lateral movement.

In response to the evolving threat landscape and the dissolution of the traditional network perimeter, this project initiates a fundamental shift in our security architecture. We will be decommissioning our legacy VPN infrastructure, which relies on an outdated castle-and-moat model that grants excessive network access and is vulnerable to lateral threat movement. To replace it, we are adopting a cloud-native, Zero Trust approach powered by Zscaler. This new architecture is built on the principle of "never trust, always verify," ensuring that users are connected to applications, not to the network. By making applications invisible to the internet and establishing direct, secure user-to-app connections, we will drastically reduce our attack surface. This modern solution eliminates the risk of lateral movement, as threats can no longer traverse a flat network. Furthermore, it provides a superior, high-performance experience for our hybrid workforce, decoupling security from data center backhauling. The transition to Zscaler will not only bolster our security posture but also enhance agility and reduce the operational overhead associated with managing legacy hardware. This initiative is a critical step in future-proofing our organization against sophisticated cyber threats.

Legacy VPN Architecture Legacy VPN architecture is a network security model that creates an encrypted tunnel between a remote user and an organization's internal network using on-premises hardware appliances like VPN concentrators . Unlike modern solutions, legacy VPNs operate on an "authenticate once, trust indefinitely" principle. Once a user successfully authenticates, they are placed directly onto the internal network with an IP address, effectively becoming a node on that network . This architecture was designed for a different era when all users were in offices and all applications were in data centers. It relies on the concept of a "trusted internal network" versus an "untrusted external internet"—the castleand-moat model . The VPN concentrator acts as the drawbridge: once crossed, the user is trusted and granted broad access to internal resources based on their IP address rather than their identity . • Limitations of Legacy VPN Legacy VPN architectures present significant security and operational challenges in today's distributed work environment. The limitations include:

1. Over-permissioned Access: Once connected, users gain network-level access, meaning a compromised faculty laptop can scan, discover, and attack other systems on the internal network (lateral movement) .

2. Expanded Attack Surface: VPN concentrators must be exposed to the public internet with open ports (typically IPsec on UDP 500 or SSL VPN on TCP 443), making them visible targets for port scanning, brute-force attacks, and vulnerability exploitation .

3. Poor User Experience: Traffic is often "hair-pinned"—routed from the user to the data center and then out to the internet for SaaS applications—causing latency and slow performance .

4. Scalability Challenges: Hardware VPN appliances have hard capacity limits. During peak times (e.g., start of semester), users face connection failures, requiring manual upgrades of expensive hardware .

5. Operational Overhead: IT staff must patch, upgrade, and maintain physical VPN appliances, applying firmware updates and managing certificates .

• The Problem: Lateral Movement and Attack Surface The core security weaknesses of legacy VPNs are the expanded attack surface and the risk of lateral movement.

Attack Surface: The VPN concentrator's publicly exposed IP address and open ports invite constant scanning and attacks. Threat actors use tools to identify VPN appliances and exploit known vulnerabilities (e.g., CVE2019-11510, a critical Pulse Secure VPN vulnerability). Each exposed port is a potential entry point .

Lateral Movement: Once an attacker gains access via a compromised credential or vulnerability, they inherit the user's network-level access. The internal network, traditionally flat, allows the attacker to move laterally. From a single compromised faculty laptop, they can:
• Scan for other vulnerable servers (e.g., databases, file shares)

• Perform ARP spoofing or pass-the-hash attacks

• Pivot to high-value targets like the student information system or research data repositories
• Deploy ransomware across the network

• Zero Trust Architecture Zero Trust Architecture (ZTA) is a security framework that eliminates the concept of trusted and untrusted networks. It operates on the principle of "never trust, always verify" and "least privilege access." Every access request is fully authenticated,

authorized, and encrypted before granting access, regardless of whether the user is in the office or working remotely . The core tenets of Zero Trust include:

1. Assume Breach: Design the network as if attackers are already present.

2. Verify Explicitly: Authenticate and authorize based on identity, device health, and context.
3. Least Privilege Access: Grant only the minimum access necessary to perform a job function.
4. Micro-segmentation: Isolate workloads and users from one another to prevent lateral movement.

• Zscaler Zero Trust Solution Zscaler is a cloud-native security platform that delivers Zero Trust capabilities entirely from the cloud, eliminating the need for on-premises VPN hardware. The solution consists of two primary components relevant to this project:

1. Zscaler Private Access (ZPA): A ZTNA service that provides seamless, identity-based access to private applications without placing users on the network. It connects users to applications, not the network .

2. Zscaler Internet Access (ZIA): A secure web gateway that inspects all internet-bound traffic for threats and data loss, protecting users regardless of location . Together, they create a comprehensive Zero Trust replacement for legacy VPN architectures.

• How Zscaler Eliminates Attack Surface Zscaler eliminates the attack surface by making the organization's applications completely invisible to the public internet. This is achieved through:
1. No Inbound Ports: Zscaler ZPA uses Zscaler App Connectors—lightweight VMs deployed in the data center—that initiate outbound connections to the Zscaler cloud. No inbound firewall ports need to be opened for remote access .

2. Application Invisibility: To an external port scanner, the university's applications do not exist. There are no IP addresses to scan, no ports to probe, and no VPN concentrators to attack .

3. DNS Resolution: ZPA does not rely on public DNS to resolve internal application names. Applications are never exposed to the public DNS infrastructure .

4. Dark Cloud Principle: The Zscaler cloud acts as a broker. Users connect to the cloud, and the cloud connects to the application. The application server never sees the user’s IP, and the user never sees the server’s IP—only the application itself .

• How Zscaler Prevents Lateral Movement Zscaler prevents lateral movement by ensuring users are connected to applications, not to the network. The mechanisms include:

1. Application Segmentation: ZPA establishes a one-to-one, encrypted micro-tunnel between the user's device and the specific application they are authorized to access. The user never receives an IP address on the internal network .

2. No Network Visibility: Because the user is not placed on the network, they cannot scan, discover, or connect to other resources. There is no routing to adjacent systems. The network is invisible .

3. Identity-Based Micro-segmentation: Access policies are tied to user identity, not IP addresses. Even if an attacker compromises a user's credentials, they can only access the specific applications that user is authorized for—nothing else .

4. Continuous Monitoring: Zscaler monitors the connection throughout the session. If suspicious behavior is detected (e.g., impossible travel, anomalous data transfer), the connection can be terminated in realtime, preventing further movement .

• Zscaler Architecture Components To understand how Zscaler replaces the legacy VPN, it is essential to understand its core components:

1. Zscaler Client Connector: A lightweight software client installed on user devices (laptops, desktops, mobile devices). It intelligently forwards traffic: • Private application traffic → ZPA for secure access • Internet-bound traffic → ZIA for security inspection • Bypassed traffic → Direct to internet (for performance)

2. Zscaler App Connector: A software component deployed as a VM in the university's data center or cloud environment. It initiates outbound connections to the Zscaler cloud and brokers connections to internal applications. Key features:

• No inbound firewall rules required • Automatically scales horizontally based on load • Can be deployed in multiple locations for high availability

3. Zscaler Cloud: The global security platform that enforces policies, brokers connections, and inspects traffic. It consists of over 150 data centers worldwide, ensuring low-latency access .
4. Zscaler Admin Portal: The centralized management console where administrators configure:
• Access policies

• Application definitions

• User and group mappings

• Security settings

• Integration Points Zscaler integrates with existing university infrastructure to leverage current investments:

Identity Provider (IdP) Integration:

1.Azure AD / Okta: Zscaler integrates with the university's existing IdP for user authentication and MFA. This ensures consistent identity management and allows users to use their existing credentials .

• SAML 2.0 / OpenID Connect: Supports modern authentication protocols for seamless single sign-on (SSO).

2. Endpoint Protection Integration: • CrowdStrike / Microsoft Defender / Tanium: Zscaler checks device posture with integrated endpoint detection and response (EDR) tools. Access can be conditional on: o Antivirus running and up-to-date o Disk encryption enabled o OS patch level current o Device not jailbroken/rooted

3. SIEM/SOAR Integration: • Splunk / Sentinel: Zscaler logs can be forwarded to the university's security information and event management (SIEM) system for centralized monitoring, alerting, and threat hunting .

4. Threat Intelligence Integration: • MISP Integration: Zscaler can consume threat intelligence feeds from MISP to block access to known malicious domains, IPs, and URLs via ZIA . • MISP (Malware Information Sharing Platform) Integration MISP is an open-source threat intelligence platform that enables sharing of indicators of compromise (IOCs) within the security community. Integrating MISP with Zscaler enhances threat detection capabilities.

1. Threat Intelligence Ingestion: • MISP aggregates IOCs from multiple sources—industry ISACs, open-source feeds, and internal threat research .

• These IOCs include malicious domains, IP addresses, URLs, and file hashes associated with known malware campaigns, phishing attacks, and command-and-control (C2) servers . 2. Integration Mechanism: • The security team configures MISP to push threat intelligence feeds to the Zscaler cloud via API .

• Zscaler normalizes this data into its threat intelligence database .

3. Proactive Blocking: • When a faculty member—even one authorized via ZPA—attempts to access a website that matches an IOC from the MISP feed, ZIA blocks the request .

4. Enhanced Threat Correlation: • Security analysts can use MISP to cross-reference Zscaler logs. For example, if anomalous outbound traffic is detected from a compromised device, analysts can query MISP to determine if the destination IP is associated with a known threat actor .

• Deployment Methodology Deploying Zscaler to replace the legacy VPN requires a structured,

phased approach:

Phase 1: Discovery and Planning (Weeks 1-2) 1. Application Discovery: Catalog all internal applications currently accessed via VPN. This includes: o Student Information System (SIS) o ERP (Finance/HR) o Library resources o Research computing clusters o Internal file servers o Administrative portals 2. User Segmentation: Define user groups and their application access requirements: o Faculty: ERP, research servers, file shares o Students: Library resources, learning management system o Staff: Administrative portals, finance applications o IT Admins: Server management interfaces o External Collaborators: Specific research applications only 3. Traffic Analysis: Understand current traffic patterns to plan Zscaler Internet Access (ZIA) forwarding methods (PAC file, tunnel, or proxy).

Phase 2: Infrastructure Deployment (Weeks 3-4) 1. Deploy App Connectors: o Provision App Connector VMs in the university data center (minimum 2 for high availability) o Configure them with outbound internet access to connect to Zscaler cloud o No inbound firewall rules required 2. Configure App Connector Groups: o Group connectors by function or location o Associate them with specific applications for traffic steering 3. Integrate Identity Provider: o Configure SAML 2.0 between Zscaler and Azure AD o Map user groups from Azure AD to Zscaler o Test authentication flow

Phase 3: Policy Configuration (Weeks 5-6) 1. Define Applications in ZPA: o Add each internal application (by IP, port, and protocol) o Associate applications with App Connector groups o Configure application segmentation 2. Create Access Policies: o Build granular policies based on user groups: ▪ "Faculty can access ERP on TCP 443 from devices with antivirus enabled after MFA" ▪ "Researchers can access HPC Cluster on TCP 22 from

managed devices only" ▪ *"External Collaborators can access Research Repository on TCP 443 between 9 AM-5 PM"* 3. Configure ZIA Policies: o Set up URL filtering o Enable threat protection (IPS/IDS) o Configure data loss prevention (DLP) rules for sensitive data

Phase 4: Pilot Deployment (Weeks 7-8) 1. Select Pilot Group: Choose a small group of willing faculty and IT staff (10-20 users). 2. Deploy Zscaler Client Connector: Provide installation instructions and assist with setup. 3. Monitor and Validate: o Verify authentication and MFA flows o Test application access o Validate that users cannot access unauthorized applications o Collect feedback on performance 4. Refine Policies: Adjust based on pilot feedback and any access issues.

Phase 5: Full Deployment and Migration (Weeks 9-12) 1. Phased Rollout: Deploy to user groups in waves: o Week 9: Faculty and researchers o Week 10: Administrative staff o Week 11: Students (if applicable) o Week 12: IT staff and remaining users 2. Communication and Training: o Send pre-deployment emails with instructions o Provide user guides for Zscaler Client Connector o Establish support channels for issues 3. Legacy VPN Decommissioning: o Once all users are migrated, revoke legacy VPN access o Shut down VPN concentrators o Remove public DNS records pointing to VPN

Phase 6: Optimization and Continuous Improvement (Ongoing) 1. Log Analysis: Regularly review Zscaler logs in the admin portal for anomalies. 2. Policy Refinement: Update policies based on changing user roles and application additions. 3. Threat Hunting: Use integrated threat intelligence (MISP) to proactively search for compromised accounts. • Threat Intelligence in Zscaler Environment Threat intelligence transforms Zscaler from an access control tool into a proactive security platform. It provides context about who is trying to access what, from where, and with what risk. Sources of Threat Intelligence: 1. Zscaler Cloud Logs: Real-time data on connections, including: o User identity and group membership o Source IP and geolocation o Destination application and IP o Bytes transferred and session duration o Device posture information 2. External Threat Feeds (MISP): Structured IOCs from trusted sources: o Known malicious domains (e.g., phishing sites) o Command-and-control server IPs o Ransomware distribution URLs o File hashes of malware samples 3. Identity Provider Logs: Authentication data from Azure AD: o Successful and failed login attempts o MFA status o Impossible travel anomalies 4. EDR Integration: Endpoint detection tools provide: o Compromised device alerts o Malware detections o Anomalous process behavior Applications of Threat Intelligence:

1. Adaptive Access Control: o If threat intelligence identifies a user's source IP as high-risk (e.g., known TOR exit node or malicious VPN), Zscaler can:

▪ Step-up authentication (require additional MFA) ▪ Block access entirely ▪ Restrict to read-only access

2.Compromised Account Hunting: o Analysts query Zscaler logs to identify:

▪ Users accessing applications at unusual hours

▪ Unusual data transfer volumes (potential exfiltration)

▪ Access from unusual geographic locations o Cross-reference with MISP to see if destination IPs are known malicious

3. Proactive Threat Blocking:

o MISP feeds are pushed to ZIA for real-time enforcement

o When any user attempts to access a blocked domain, the request is denied

Alerts are generated for security team investigation

Conclusion :-

In conclusion, exploring the realm of AI for web security using IBM QRadar has been an insightful journey through various stages.

- **Stage 1 :**understanding web application testing unveiled the critical importance of assessing vulnerabilities and ensuring the security of web-based systems. This foundational knowledge served as a cornerstone for comprehending the subsequent stages.
- **Stage 2 :-** delved into the intricacies of Nessus reports, emphasising the significance of detailed vulnerability assessments. Analysing these reports provided valuable insights into potential threats, enabling informed decision-making for robust security measures.

- **Stage 3 :- The replacement of the legacy VPN architecture with a cloud-native Zscaler Zero Trust solution marks a pivotal transformation in the organization's security posture. By shifting from a network-centric to an application-centric model, this project successfully eliminates the expanded attack surface inherent in publicly exposed VPN concentrators and completely eradicates the risk of lateral movement. The implementation of Zscaler Private Access (ZPA) ensures that users are connected only to specific applications after rigorous identity and device verification, rendering the internal network invisible. This modernization not only fortifies defenses against sophisticated cyber threats but also delivers a superior, low-latency experience for the hybrid workforce, establishing a future-ready security foundation..**

Future Scope :-

- **Stage 1 :-** illuminated the evolving landscape of web application testing. With advancements in AI, there is a promising avenue for more sophisticated testing methodologies, ensuring even higher levels of security for web applications.
- **Stage 2 :**highlighted the future trajectory of the testing process, indicating a shift towards more automation and integration of AI-driven tools. This evolution promises quicker, more accurate vulnerability assessments, enhancing overall cybersecurity postures**.**
- **Stage 3 :**illuminated the future potential of Zero Trust Network Access (ZTNA) and Zscaler technologies. With AI integration and machine learning, these systems are poised to become more intelligent and adaptive, enabling real-time risk assessment based on user behavior and device posture. Enhanced automation in policy enforcement, predictive analytics for threat detection, and improved scalability are anticipated, empowering organizations to stay ahead of sophisticated cyber threats in an increasingly distributed world

Topics explored :- Data Collection and Aggregation, Standardization and Normalisation, Enrichment and Analysis, Sharing and Distribution, Integration with Security Tools,

Customization and Flexibility, Automation and Orchestration, Community Involvement, Incident Response Support, Threat Intelligence Feeds, Soc and Siem

Tools explored: - Nmap, Metasploit, Nessus, Kali Linux, OWASP ZAP, Burp Suite THE EN

THE END